

# Automatizando a Identificação de Ativos Críticos para Priorização de Correções de Segurança

Janderson Barbosa da Silva<sup>1</sup>, Rafael R. Obelheiro<sup>1</sup>

<sup>1</sup>Programa de Pós-Graduação em Computação Aplicada (PPGCAP)  
Universidade do Estado de Santa Catarina (UDESC) – Joinville, SC – Brasil

janderson.silva@edu.udesc.br, rafael.obelheiro@udesc.br

**Resumo.** *O volume crescente de vulnerabilidades divulgadas anualmente torna inviável a correção imediata de todas as falhas, exigindo processos de priorização que considerem não apenas a severidade técnica, mas também a importância dos ativos afetados. Contudo, propostas que incorporam a criticidade dos ativos geralmente dependem de avaliações manuais, sujeitas a vieses e desatualizações. Este trabalho propõe um modelo para identificação automatizada da criticidade dos ativos, baseado em atributos técnicos observáveis coletados diretamente da infraestrutura.*

## 1. Introdução

O volume de vulnerabilidades de software divulgadas anualmente cresce em ritmo acelerado: em 2024, foram publicados 40.009 novos registros no National Vulnerability Database (NVD), um aumento de 39% em relação ao ano anterior [Gamblin 2025]. Em ambientes com centenas ou milhares de ativos, a correção imediata de todas as falhas é operacionalmente inviável: fatores como limitações de pessoal, janelas de manutenção e riscos de instabilidade tornam a priorização uma necessidade fundamental [Souppaya and Scarfone 2022].

As abordagens mais adotadas para essa priorização baseiam-se em métricas técnicas de severidade como Common Vulnerability Scoring System (CVSS), Exploit Prediction Scoring System (EPSS) e Stakeholder-Specific Vulnerability Categorization (SSVC), que avaliam as propriedades intrínsecas das vulnerabilidades, mas ignoram o papel dos ativos afetados no contexto operacional [Jiang et al. 2025]. Por exemplo, um servidor de autenticação e uma estação de trabalho isolada podem compartilhar a mesma pontuação CVSS, mas representam riscos organizacionais completamente distintos. Modelos que incorporam a criticidade dos ativos ao processo de priorização existem, mas dependem de avaliações manuais, sujeitas a vieses individuais e à necessidade de conhecimento especializado do ambiente [Parente et al. 2025].

Este trabalho propõe um modelo para identificação automatizada da criticidade dos ativos, com base em atributos técnicos coletados diretamente da infraestrutura como: conexões estabelecidas, serviços expostos, volume de tráfego e relações de dependência. O objetivo é fornecer uma entrada objetiva e atualizada para processos de priorização de vulnerabilidades, reduzindo a dependência de avaliações manuais e tornando a gestão de risco mais escalável e alinhada à realidade operacional.

## 2. Fundamentação e Trabalhos Relacionados

A gestão de vulnerabilidades é um processo contínuo orientado à identificação, avaliação, priorização e tratamento de falhas de segurança [Souppaya and Scarfone 2022]. O CVSS

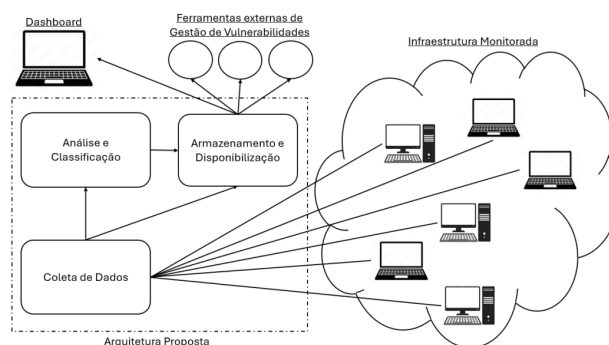
fornece uma base técnica padronizada para avaliar severidade, mas ignora o contexto organizacional [FIRST 2023]. O EPSS estima a probabilidade de exploração nos próximos 30 dias com base em evidências empíricas, porém também não considera a importância do ativo [Jacobs et al. 2021]. O SSVC incorpora fatores organizacionais, mas exige avaliações qualitativas manuais de difícil escalabilidade [Spring et al. 2021].

Uma revisão sistemática da literatura identificou que, nos trabalhos existentes sobre priorização de vulnerabilidades e identificação da criticidade de ativos, a criticidade é tratada como entrada previamente definida por especialistas ou sistemas externos. Modelos como VULCON [Farris et al. 2018], CyberTOMP [Domínguez-Dorado et al. 2022] e FRAPE [Parente et al. 2025] representam avanços ao incorporar variáveis contextuais, mas ainda dependem de inventários manuais e classificações atribuídas por especialistas.

Essa dependência imposta pelos modelos existentes implica três desafios principais: (i) baixa escalabilidade, dado que a análise manual de grande quantidade de ativos por especialistas é inviável; (ii) viés subjetivo, decorrente da variabilidade entre analistas e critérios institucionais; e (iii) forte dependência de conhecimento prévio do ambiente, dificultando a aplicação em contextos desconhecidos ou terceirizados. Nenhum dos trabalhos revisados propõe um mecanismo nativo que avalie a importância de um ativo com base em seu comportamento observável na infraestrutura, e essa é justamente a lacuna que este trabalho busca preencher.

### 3. Proposta

O objetivo central é desenvolver um mecanismo capaz de classificar automaticamente os ativos de uma infraestrutura computacional em níveis de criticidade, com base em atributos técnicos extraídos de forma autônoma. A arquitetura estrutura-se em três camadas, conforme ilustrado na Figura 1.



**Figura 1. Arquitetura do modelo proposto.**

#### 3.1. Coleta de atributos

Extrai continuamente oito atributos observáveis da infraestrutura: (i) conexões de entrada únicas — número de endereços IP distintos que iniciaram conexões com o ativo; (ii) tráfego total — volume de dados transmitidos e recebidos; (iii) vizinhos internos — quantidade de ativos da rede interna com os quais o ativo se comunica; (iv) serviços críticos em execução — processos associados a funções essenciais como autenticação, resolução de nomes e acesso a dados; (v) portas críticas abertas — portas associadas a serviços essenciais de infraestrutura em estado de escuta, indicando quais funções operacionais o

ativo provê; (vi) tráfego em portas críticas — volume de dados nessas portas, refletindo a intensidade de uso dessas funções; (vii) StrongPorts — portas de serviços relevantes predefinidos que, embora não classifiquem o ativo como provedor de infraestrutura essencial, ampliam sua superfície de exposição e evidenciam maior complexidade operacional; e (viii) portas em escuta únicas — contagem total de portas TCP e UDP distintas em estado de escuta, independentemente de sua classificação, capturando a amplitude geral da superfície exposta pelo ativo.

### **3.2. Análise e classificação**

Os oito atributos são organizados em cinco dimensões complementares: conectividade, volume, função, demanda e exposição, seguindo o princípio de cobertura multidimensional adotado em trabalhos de priorização baseados em múltiplos critérios [Jiang et al. 2025, Farris et al. 2018]. Esses atributos são submetidos ao método Technique for Order of Preference by Similarity to Ideal Solution (TOPSIS), que compara cada ativo simultaneamente à solução ideal positiva e negativa, gerando um índice contínuo entre 0 e 1 [Yoon and Hwang 1995]. Com base nesse índice, os ativos são ordenados em um ranqueamento de criticidade, permitindo identificar quais servidores representam maior risco operacional em caso de comprometimento ou indisponibilidade. Pesos iguais são adotados como configuração padrão. O índice pode ser mapeado para faixas qualitativas como: baixa, média, alta e muito alta, para facilitar a interpretação operacional. Essa abordagem complementa métricas centradas na vulnerabilidade, como o CVSS [FIRST 2023], ao incorporar o contexto operacional do ativo afetado.

### **3.3. Armazenamento e disponibilização**

Registra os índices e os atributos que fundamentaram cada decisão, permitindo auditorias e integração com ferramentas externas de gestão de vulnerabilidades. Alterações na infraestrutura são refletidas automaticamente, sem intervenção manual.

## **4. Avaliação Experimental**

A avaliação inicial foi conduzida em uma organização de pequeno porte, com 8 servidores ativos. O protótipo coletou os oito atributos da infraestrutura, submeteu-os ao TOPSIS e gerou um ranqueamento de criticidade sem qualquer configuração manual prévia ou conhecimento antecipado do ambiente.

O ranqueamento resultante foi apresentado ao responsável de TI da organização, que confirmou a ordenação como compatível com sua percepção sobre quais ativos são mais críticos para a operação. Esse resultado indica que atributos técnicos observáveis são suficientes para aproximar a criticidade real dos ativos, sem depender de inventários manuais ou avaliações especializadas prévias.

Uma validação mais ampla, com aplicação de questionário estruturado em organização de maior porte e complexidade está planejada como próxima etapa. Essa validação, que contará com a colaboração de vários especialistas, permitirá mensurar quantitativamente a concordância entre o modelo e o julgamento especializado.

## **5. Considerações Finais**

Este trabalho propôs um modelo para identificação automatizada da criticidade de ativos de rede, baseado na coleta autônoma de oito atributos técnicos e no ranqueamento

multicritério via TOPSIS. A validação inicial em ambiente real, com confirmação do responsável de TI da organização, indica que atributos observáveis são suficientes para aproximar a criticidade real dos ativos sem depender de inventários manuais ou avaliações especializadas prévias.

A área de gestão de vulnerabilidades enfrenta um esforço crescente para incorporar o contexto operacional dos ativos aos processos de priorização. O modelo proposto complementa esse esforço ao fornecer uma entrada objetiva e automaticamente atualizada sobre a importância de cada ativo na infraestrutura, reduzindo a subjetividade inerente às abordagens manuais vigentes.

Em sua versão atual, o modelo restringe-se a atributos internos e observáveis, não contemplando fatores como impacto financeiro, conformidade regulatória ou inteligência de ameaças. A validação quantitativa em organização de maior porte, o refinamento das ponderações TOPSIS e a adequação do modelo a infraestruturas de processamento de alto desempenho representam as principais direções para trabalhos futuros.

**Agradecimentos** Os autores agradecem o apoio da Udesc e da FAPESC.

## Referências

- Domínguez-Dorado, M., Carmona-Murillo, J., Cortés-Polo, D., and Rodríguez-Pérez, F. J. (2022). CyberTOMP: A novel systematic framework to manage asset-focused cybersecurity from tactical and operational levels. *IEEE Access*, 10:122454–122485.
- Farris, K. A., Shah, A., Cybenko, G., Ganesan, R., and Jajodia, S. (2018). VULCON: A system for vulnerability prioritization, mitigation, and management. *ACM Transactions on Privacy and Security*, 21(4).
- FIRST (2023). Common vulnerability scoring system version 4.0 specification document. <https://www.first.org/cvss/v4.0/specification-document>.
- Gamblin, J. (2025). 2024 CVE data review. <https://jerrygamblin.com/2025/01/05/2024-cve-data-review/>. Acesso em: fev. 2026.
- Jacobs, J., Romanosky, S., Edwards, B., Roytman, M., and Adjerid, I. (2021). Exploit prediction scoring system. *Digital Threats: Research and Practice*, 2(3).
- Jiang, Y., Oo, N., Meng, Q., Lim, H. W., and Sikdar, B. (2025). A survey on vulnerability prioritization: Taxonomy, metrics, and research challenges. *arXiv preprint arXiv:2502.11070*.
- Parente, F. R., Rodrigues, E. B., and Mattos, C. L. C. (2025). FRAPE: A framework for risk assessment, prioritization and explainability of vulnerabilities in cybersecurity. *Journal of Information Security and Applications*, 89.
- Souppaya, M. and Scarfone, K. (2022). Guide to enterprise patch management planning: Preventive maintenance for technology. Technical Report NIST SP 800-40 Rev. 4, National Institute of Standards and Technology.
- Spring, J., Hatleback, E., Householder, A., Manion, A., and Shick, D. (2021). Prioritizing vulnerability response: A stakeholder-specific vulnerability categorization. In *Workshop on the Economics of Information Security (WEIS)*.
- Yoon, K. P. and Hwang, C.-L. (1995). *Multiple Attribute Decision Making: An Introduction*. Sage Publications.